

HealthData Alliance BCR 审查报告草案

BCR-C 合规审查报告

审查对象：HealthData Alliance

审查范围：BCR Document-Driven Review (BCR-C)

审查日期：20260808

综合评级：高风险

关键发现

Binding nature (internal and external) 覆盖不完整；Third-party beneficiary rights 覆盖不完整；EU liable entity designation 覆盖不完整；Complaint handling mechanism 覆盖不完整；缺失 Cooperation with supervisory authorities

详细审查结果

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .1	Binding nature (internal and external) 覆盖不完整	HIGH	Binding nature (internal and external) 部分覆盖但缺少关键要素. 依据：GDPR Article 47(1)(a), EDPB Recommendations 1/2022。证据：未提及集团内协议或其他具有法律约束力的内部文书	应补充 Binding nature (internal and external) 的完整内容。	GDPR Article 47(1)(a) [1]；EDPB Recommendations 1/2022
BCR -C-1 .2	Third-party beneficiary rights 覆盖不完整	HIGH	Third-party beneficiary rights 部分覆盖但缺少关键要素. 依据：GDPR Article 47(1)(b), EDPB Recommendations 1/2022。证据：文本未包含数据主体可直接强制执行 BCR 的第三方受益人权利描述	应补充 Third-party beneficiary rights 的完整内容。	GDPR Article 47(1)(b) [1]；EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .3	EU liable entity designation 覆盖不完整	HIGH	EU liable entity designation 部分覆盖但 缺少关键要素. 依据：GDPR Article 47(2)(f), EDPB Recommendations 1/2022 。证据：未指定一个在 欧盟境内设立的实体作 为承担BCR合规责任的 主体	应补充 EU liable entity designation 的完整内容。	GDPR Article 47(2)(f) [1]；EDPB Recommendations 1/2022
BCR -C-1 .6	Complaint handling mechanism 覆盖不完整	MEDIUM	Complaint handling mechanism 部分覆盖但 缺少关键要素. 依据：GDPR Article 47(2)(e), EDPB Recommendations 1/2022 。证据：未明确投诉处 理的时限（如一个月内 ）	应补充 Complaint handling mechanism 的完整内容。	GDPR Article 47(2)(e)；EDPB Recommendations 1/2022
BCR -C-1 .7	缺失 Cooperation with supervisory authorities	MEDIUM	未在文档中找到 Cooperation with supervisory authorities 的相关内容. 依据：GDPR Article 47(2)(f), EDPB Recommendations 1/2022。证据：	应补充 Cooperation with supervisory authorities 的完整内容。	GDPR Article 47(2)(f)；EDPB Recommendations 1/2022
BCR -C-1 .8	Onward transfer restrictions 表述模糊	HIGH	Onward transfer restrictions 使用了模糊 表述，未达到具体可执 行标准. 依据：GDPR Chapter V, EDPB Recommendations 1/2022 。证据：使用'substantia lly similar'等笼统表述定 义保护标准，未指向具 体GDPR保护水平或SC C	应补充 Onward transfer restrictions 的完整内容。	GDPR Chapter V；EDPB Recommendations 1/2022

检 查 项	主题	风 险	现状	整改建议	法律依据
BCR -C-1 .9	Third country law assessment (TIA) 覆盖不完整	HIGH	Third country law assessment (TIA) 部分覆 盖但缺少关键要素. 依据：Schrems II, EDPB 01/2020, EDPB Recommendations 01/202 0。证据：未说明使用E DPB六步法或其他结构 化方法进行TIA	应补充 Third country law assessment (TIA) 的完整内容。	Schrems II, EDPB 01/2020 [2]；EDPB Recommendations 01/2020
BCR -C-1 .10	缺失 Audit and training mechanisms	MEDIUM	未在文档中找到 Audit and training mechanisms 的相关内容. 依据：GDPR Article 47(2)(h), EDPB Recommendations 1/2022。证据：	应补充 Audit and training mechanisms 的完整内容。	GDPR Article 47(2)(h)；EDPB Recommendations 1/2022
BCR -C-1 .12	Termination and exit provisions 覆盖不完整	MEDIUM	Termination and exit provisions 部分覆盖但缺 少关键要素. 依据：GDPR Article 47(2)(j), EDPB Recommendations 1/2022 。证据：命中关键词: ['end']	应补充 Termination and exit provisions 的完整内容。	GDPR Article 47(2)(j)；EDPB Recommendations 1/2022
BCR -SH ARE D-2	Personal data breach notification 覆盖不完整	MEDIUM	Personal data breach notification 部分覆盖但 缺少关键要素. 依据：, GDPR Article 33, 34。证据：命中关键词: ['breach']	应补充 Personal data breach notification 的完整内容。	；GDPR Article 33, 34

高风险项目

Binding nature (internal and external) 覆盖不完整；Third-party beneficiary rights 覆盖不完整；EU liable entity designation 覆盖不完整；Onward transfer restrictions 表述模糊；Third country law assessment (TIA) 覆盖不完整；未明确指定 EU 责任主体；未赋予数据主体第三方受益人权利；转委托处理缺乏书面授权机制；缺少法律约束力文书具体说明

中风险项目

Complaint handling mechanism 覆盖不完整；缺失 Cooperation with supervisory authorities；缺失 Audit and training mechanisms；Termination and exit provisions 覆盖不完整；Personal data breach notification 覆盖不完整；Government access request handling 覆盖不完整；TIA 未引用 EDPB 结构化评估方法；TIA 缺少定期审查机制；TIA 未提及补充保护措施；TIA 缺少无法缓解风险时的中止条款；未明确限制向非 BCR 成员传输；缺少转委托授权机制；EU 责任主体未明确承诺责任/赔偿；缺少数据主体救济渠道说明；TIA 评估方法不够完整；投诉处理时限未明确；缺少子处理者变更通知机制

低风险项目

无

整改路线图

高风险项（需立即整改）：

- Binding nature (internal and external) 覆盖不完整
- Third-party beneficiary rights 覆盖不完整
- EU liable entity designation 覆盖不完整
- Onward transfer restrictions 表述模糊
- Third country law assessment (TIA) 覆盖不完整

可直接采用的建议条款

- BCR-C-1.1 Binding nature (internal and external) 覆盖不完整：1.1 有约束力的性质

这些有约束力的公司规则（下称“BCR”）构成HEALTHDATA

ALLIANCE集团内部具有法律约束力的公司政策。所有集团成员均通过签署《HEALTHDATA ALLIANCE集团数据保护协议》（下称“集团协议”）或其他具有同等法律约束力的内部文书，承诺遵守本BCR的所有条款。本BCR对集团内所有处理个人数据的实体具有强制约束力，并构成GDPR第47条所指的具有法律约束力和可执行性的承诺。集团成员之间的权利义务关系，包括就本BCR的遵守情况相互承担责任，由前述集团协议具体规定。本BCR亦旨在为欧盟/欧洲经济区内的数据主体提供可执行的权利，并可由相关监管机构直接针对任何集团成员执行。

- BCR-C-1.2 Third-party beneficiary rights 覆盖不完整：第三方受益人权利：根据《通用数据保护条例》第47(1)(b)条，数据主体作为第三方受益人，有权依据本有约束力的公司规则（控制者）强制执行其中关于其个人数据保护的规定，包括获得救济和赔偿的权利。本规则旨在为数据主体提供可执行的权利，且不损害数据主体根据适用数据保护法律享有的其他权利。

- BCR-C-1.3 EU liable entity designation 覆盖不完整：1.3 欧盟责任实体

为履行本BCR下的责任，特别是在GDPR第47(

- 1 (f)条和EDPB建议1/2022的要求下，[在欧盟境内设立的实体名称，例如：HealthData Alliance EU Ltd.]（以下简称“欧盟责任实体”）被指定为在欧盟境内承担BCR合规责任的主体。该实体位于[完整的欧盟地址]。欧盟责任实体应作为BCR集团在欧盟的主要联络点，负责监督BCR的遵守情况，处理数据主体行使权利的请求，并与监管机构合作。欧盟责任实体对其处理活动直接负责，并对BCR集团内其他成员的处理活动承担连带责任，除非能证明其对导致损害的事件不负有责任。

- BCR-C-1.8 Onward transfer restrictions 表述模糊：[Insert specific clause addressing the identified requirement in accordance with GDPR Article 47 and EDPB Recommendations]

- BCR-C-1.9 Third country law assessment (TIA) 覆盖不完整：1.9 第三国法律评估

为确保根据本BCR向欧盟/欧洲经济区以外传输的个人数据得到与欧盟/欧洲经济区内同等的保护水平，HEALTHDATA ALLIANCE承诺对所有接收数据的第三国进行系统性的第三国法律评估（Transfer Impact Assessment, TIA）。该评估将严格遵循欧洲数据保护委员会（EDPB）在Recommendations

01/2020中概述的六步法框架，并充分考虑Schrems II判决的法律原则。评估过程将至少包括以下关键要素：(a)

识别传输情境；(b) 评估第三国相关法律及实践；(c) 评估传输情境下数据接收方可能适用的法律；(d) 识别并评估接收方所在第三国法律中可能影响本BCR保障措施有效性的具体规定；(e) 评估为补充保障措施而可能采取的技术或组织措施；(f) 根据评估结果采取必要行动并定期重新评估。评估的详细方法、执行流程、责任分配及文档要求将在本BCR的实施附录中具体规定。

● BCR-C-1.3 未明确指定 EU 责任主体：1.3 责任实体

为履行本BCR项下的义务并承担GDPR第47(

1 (b)及47(

2 (f)条规定的责任， HealthData

Alliance指定其位于欧盟境内的实体【请在此处插入欧盟实体的法定名称，例如：HealthData Alliance EU Headquarters GmbH】，注册地址为【请在此处插入完整注册地址】，作为本BCR的主要责任实体（“ 责任实体 ”）。该责任实体应负责确保本BCR得到遵守，并作为欧盟数据保护监管机构和数据主体在涉及本BCR事宜的主要联络点。责任实体应拥有履行其职责所需的权力和资源，且其责任不因集团内其他实体可能承担的责任而免除。

● BCR-C-1.3 未赋予数据主体第三方受益人权利：第三方受益人权利

数据主体作为本BCR的第三方受益人，有权直接依据本BCR向HealthData Alliance成员主张其数据保护权利，并强制执行本BCR的条款。此项权利独立于数据主体根据适用数据保护法律（包括但不限于GDPR）所享有的任何其他权利或救济措施。

● BCR-C-1.1 转委托处理缺乏书面授权机制：These Binding Corporate Rules constitute a legally binding instrument that is enforceable by all BCR members against each other and by data subjects as third-party beneficiaries. Each BCR member shall enter into an intra-group agreement that expressly incorporates these Rules and creates binding obligations under the law of [EU Member State].

● BCR-C-1.1 缺少法律约束力文书具体说明：These Binding Corporate Rules constitute a legally binding instrument that is enforceable by all BCR members against each other and by data subjects as third-party beneficiaries. Each BCR member shall enter into an intra-group agreement that expressly incorporates these Rules and creates binding obligations under the law of [EU Member State].